

Cyber Blog — Progetto Finale Cyber

Relazione di **Sara Spadafina** sull'analisi e mitigazione di sei vulnerabilità web (OWASP Top 10) in un'applicazione Laravel 11 con architettura a tre livelli di rete: Internet, DMZ e Rete Interna.

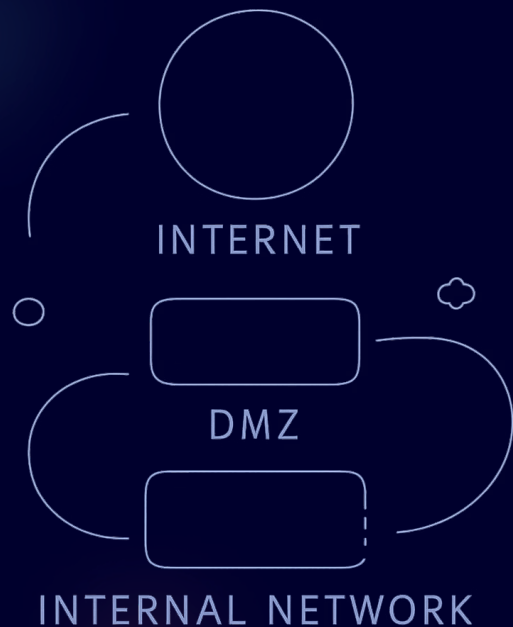
SICUREZZA WEB

LARAVEL 11

OWASP TOP 10



Architettura e Metodologia



Architettura Simulata

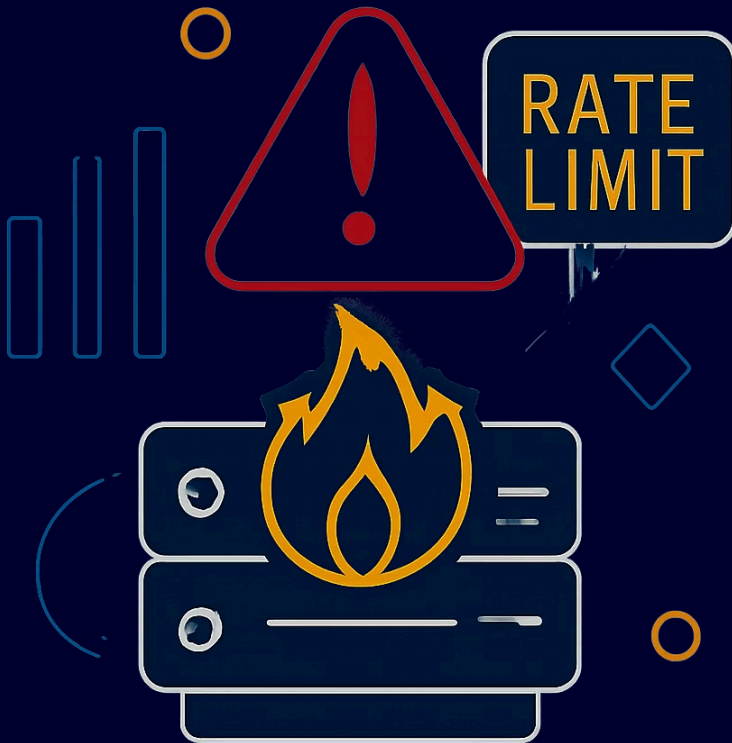
Tre domini su 127.0.0.1 per simulare reti distinte:

- `cyber.blog:8000` – applicazione pubblica (DMZ)
- `internal.admin:8000` – pannello admin (Rete Interna)
- `internal.finance:8001` – Financial App (Internal Subnet)

Metodologia per Ogni Challenge

Scenario → Attacco (con prova) → Mitigazione → Verifica (riesecuzione).

Challenge 1 & 2 — DoS e CSRF



Challenge 1 — Rate Limiter Mancante

500 richieste parallele sulla ricerca pubblica causavano DoS (90s di risposta). **Mitigazione:** middleware `BlockSuspiciousIPs` con blocco IP dopo 5 richieste/minuto.

Challenge 2 — Operazioni Critiche in GET

Le rotte di assegnazione ruoli (GET) erano vulnerabili a CSRF tramite pagina trappola. **Mitigazione:** conversione a PATCH con form protetti da token CSRF nativo.

- ✓ Entrambe le challenge mitigate: blocco confermato dopo 5 richieste/minuto e errore 405 Method Not Allowed per richieste GET malevole.

Challenge 3 & 4 — Log e SSRF

Challenge 3 — Log Mancanti

Aggiunti log per: login/logout/registrazione, gestione articoli, assegnazione ruoli e blocchi IP anomali. Tracciamento verificato end-to-end in `storage/logs/laravel.log`.

Challenge 4 — SSRF

Un utente Writer poteva accedere a `internal.finance` manomettendo il menu a tendina. **Mitigazione:** whitelist degli URL in Livewire + controllo ruolo admin in `HttpService`.

Log File

🕒 10644GB RTT Fleind login

🕒 19 97 19-71 1 dogud in

🕒 10144GB RTT Umuxdterzed
C OD # FC

🕒 1917 18-71 1 eggud cut

Challenge 5 & 6 — Stored XSS e Mass Assignment

Challenge 5 — Stored XSS

Il campo `body` degli articoli veniva renderizzato con `{!! !!}` senza sanificazione. Payload `<script>alert('hacked')</script>` eseguito automaticamente. **Mitigazione:** metodo `Article::sanitizeBody()` con whitelist tag e rimozione handler pericolosi, applicato a salvataggio e visualizzazione.

Challenge 6 — Mass Assignment

I campi `is_admin`, `is_revisor`, `is_writer` in `$fillable` permettevano auto-assegnazione ruoli tramite campo nascosto nel form. **Mitigazione:** rimossi i campi sensibili da `$fillable`; assegnazione ruoli tramite assegnazione diretta in `AdminController`.

✓ Entrambe mitigate: script mostrato come testo innocuo e campo `is_admin` ignorato silenziosamente da Eloquent.

Conclusioni

Tutte e sei le challenge completate con approccio sistematico: attacco dimostrato, mitigazione implementata e verificata tramite riesecuzione.

#	Vulnerabilità	Stato
1	Rate Limiter Mancante (DoS)	✓ Completata
2	Operazioni Critiche in GET (CSRF)	✓ Completata
3	Log Mancanti per Operazioni Critiche	✓ Completata
4	Manomissione Input (SSRF)	✓ Completata
5	Stored XSS	✓ Completata
6	Mass Assignment	✓ Completata

Possibili Sviluppi Futuri

- Scansione OWASP ZAP per ulteriori margini di miglioramento
- Adozione delle Policy di Laravel per centralizzare l'autorizzazione
- Verifica ricerca full-text con Laravel Scout